

You ship pieces. Nothing carries the release.

You sign the pieces. Nothing signs the release.

Open Component Model — open source, NeoNephos Foundation.



DIAGNOSIS

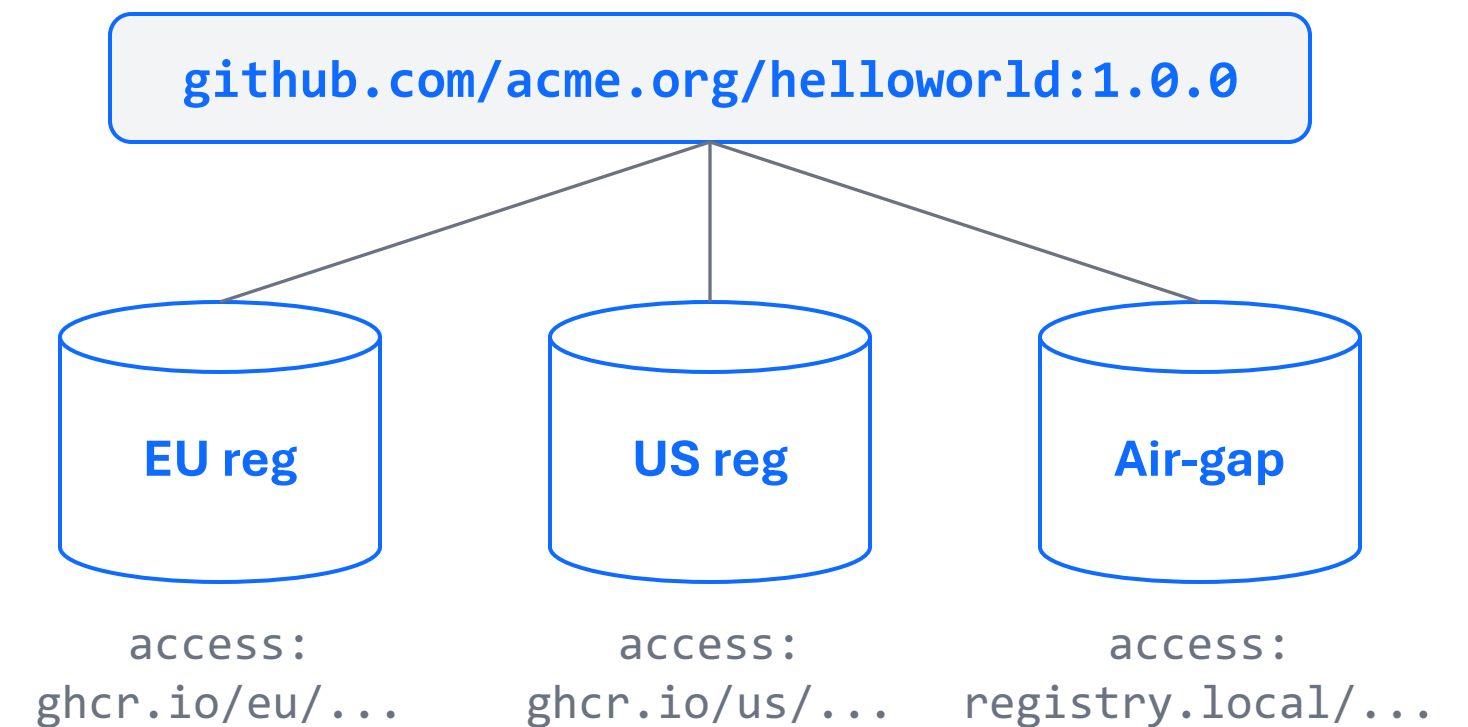
In every existing tool, identity is bound to location.

- **OCI image** — identified by registry/repo:tag. Mirror it; every downstream reference is invalidated.
- **Helm chart** — identified by repo URL + name + version. Mirror the repo; pulls fail.
- **SBOM** — linked to its subject by file path or naming convention. Move the artifact; the link dangles.

THE HINGE

Identity that travels with the artifact.

- **Component identity** — name and version of the component. Globally unique. Location-agnostic.
- **Digest** — every resource inside the component carries a content hash. Computed once.
- **Access** — where the resource currently lives. Rewritten on transfer. Digest stays.



WHERE OCM SITS

One component wraps every artifact, signed once.

ANY FORMAT

OCI, Helm, configs, SBOMs, npm, maven, binaries.

Artifact type is free-form; access types are pluggable.

ANY LOCATION

Component identity travels.

The component carries its name across registries.

ONE SIGNATURE

Covers every digest in the component.

Survives transport.

CONSTRUCTOR

What you write.

```
components:
- name: github.com/acme.org/helloworld
  version: 1.0.0
  provider:
    name: acme.org
  resources:
    - name: mylocalfile
      type: blob
      input:                                # Embed by value
        type: File/v1
        path: ./my-local-resource.txt
    - name: image
      type: ociImage
      version: 1.0.0
      access:                              # Reference external artifact
        type: OCIImage/v1
        imageReference: ghcr.io/stefanprodan/podinfo:6.9.1
```

input: by value

Embed bytes at pack time.

access: by reference

Resolve external artifact at pack time.

DESCRIPTOR

What gets signed and travels.

```
component:                                # (fields trimmed)
  name: github.com/acme.org/helloworld
  version: 1.0.0
  resources:
    - name: image
      type: ociImage
      access:                               # excluded from signature
        type: OCIImage/v1
        imageReference: ghcr.io/stefanprodan/podinfo@sha256:8fa569...
      digest:                               # input to hash
        hashAlgorithm: SHA-256
        value: 262578cde928d5c9eba3bce0...
    - ...                                  # more resources, references
  signatures:
    - name: acme-release-key
      digest:                               # of the whole descriptor
        hashAlgorithm: SHA-256
        value: a4b1c2d3e4f5...
      signature:
        algorithm: RSASSA-PSS
        value: <hex-encoded signature>
```

access: excluded

Rewritten on every transfer.

digest: content identity

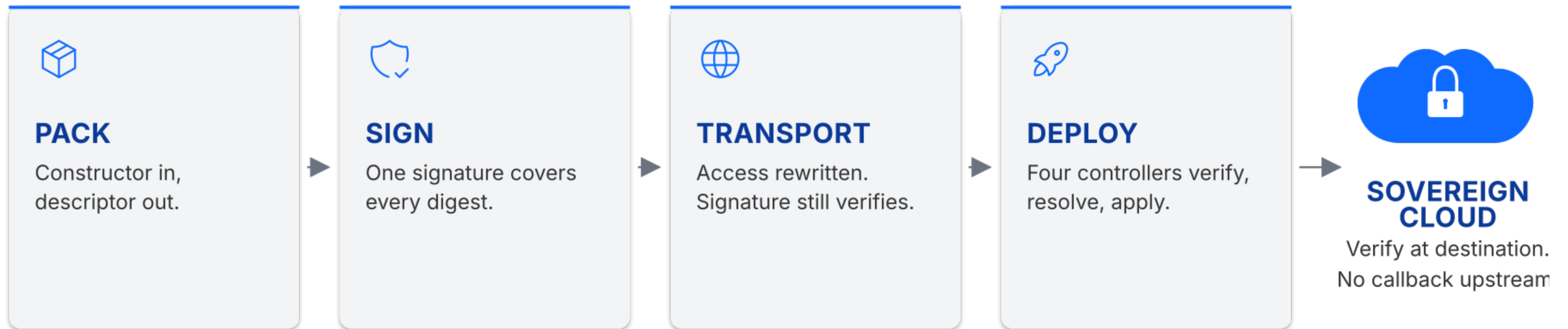
Input to the descriptor hash.

signature: one hash

Over the canonicalized descriptor.

THE FOUR MOVES

Pack · Sign · Transport · Deploy.



COMPOSE

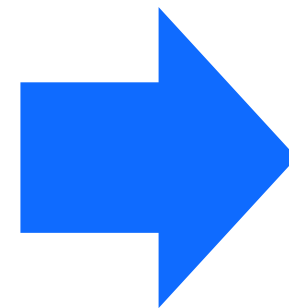
Service carries resources. Product carries references.

Service components carry resources — images, charts, configs, SBOMs, ...

A product component composes other components. One release unit, transferable, signable end-to-end.

SERVICE

```
components:
- name: acme.org/sovereign/notes
  version: 1.0.0
  resources:
    - name: image      # OCI image
    ...
    - name: chart      # Helm chart
    ...
- name: acme.org/sovereign/postgres
  version: 1.0.0
  resources:
    - name: image      # OCI image
    ...
    - name: chart      # Helm chart
    ...
# product references both, by name and version
```



PRODUCT

```
components:
- name: acme.org/sovereign/product
  version: 1.0.0
  componentReferences:
    - name: notes
      componentName: acme.org/sovereign/notes
      version: 1.0.0
    ...
    - name: postgres
      componentName: acme.org/sovereign/postgres
      version: 1.0.0
    ...
# no resources of its own – pure composition
```


SIGN

Same signed object. Three trust models.

RSA

Bare public-key pinning.
The key you already rotate.

GPG

OpenPGP keys.
Familiar trust model, ASCII-
armored.

SIGSTORE

Keyless via OIDC.
Identity, not long-lived keys.

TRANSPORT

Three patterns. One command.

REGISTRY → REGISTRY

Promote across stages.

Source registry to target registry.

REGISTRY → CTF

Export to a local archive.

Hand-carry across the boundary.

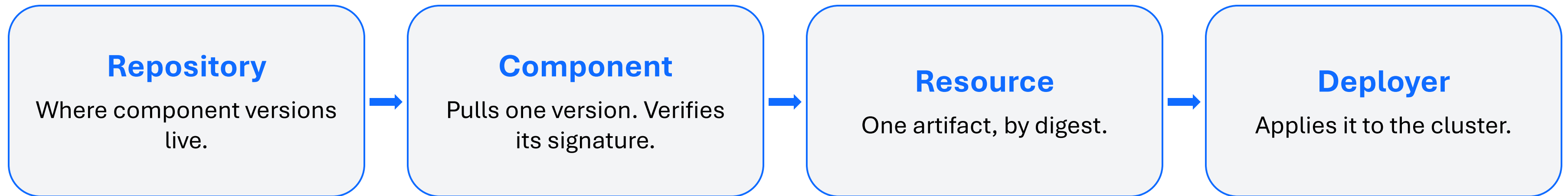
CTF → REGISTRY

Air-gap import.

Verify on arrival. No callback to source.

DEPLOY

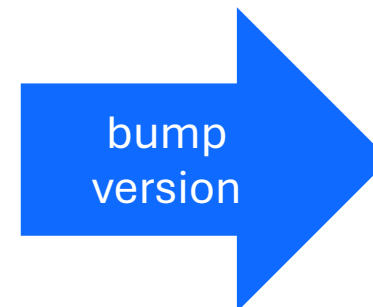
OCM controllers verify and apply.



DAY 2

Bump the product version. Everything follows.

```
component:  
  name: acme.org/sovereign/product  
  version: 1.0.0  
  componentReferences:  
    - name: notes  
      componentName: acme.org/sovereign/notes  
      version: 1.0.0  
    - name: postgres  
      componentName: acme.org/sovereign/postgres  
      version: 1.0.0  
  signatures:  
    - name: acme-release-key  
      signature:  
        algorithm: RSASSA-PSS  
        value: a4b1c2d3e5f678abc01234def04691...
```



```
component:  
  name: acme.org/sovereign/product  
  version: 1.1.0  
  componentReferences:  
    - name: notes  
      componentName: acme.org/sovereign/notes  
      version: 1.1.0  
    - name: postgres  
      componentName: acme.org/sovereign/postgres  
      version: 1.0.0  
  signatures:  
    - name: acme-release-key  
      signature:  
        algorithm: RSASSA-PSS  
        value: 9c2af18b3e7d5914a8cb0f1d2e8f37...
```

Every digest pinned by the signature. The cluster cannot drift.

ADOPTION

Two paths to a first OCM component.

FROM ZERO — CLI

Pack one component. Sign it.

Air-gap CTF round-trip.

Verify on the other side.

Thirty minutes. One afternoon.

ON YOUR CLUSTER — CONTROLLERS

Helm-install the OCM controllers.

Point them at your registry.

Deploy a component.

Thirty minutes. One reconciling cluster.

WHAT'S SHARP

Three honest edges.

- **Transfer defaults** — copies only the descriptor. For air-gap, pass `--copy-resources` so the bytes travel too.
- **Controllers are v1alpha1** — the CRD surface can move. Pin minor versions in your platform installs.
- **PEM-encoded RSA (cert chains) is experimental** — the CLI prints ``experimental`` warnings on sign/verify. Plain RSA, GPG, and Sigstore are stable on the same v1alpha1 surface

Ship the release as one unit.

Evaluate — ocm.software · run conformance/scenarios/sovereign

Pilot — github.com/open-component-model · one product, one team

Engage — community channels on the website · NeoNephos Foundation

APPENDIX · REPLICATION

Alongside the chain. Not within it.

